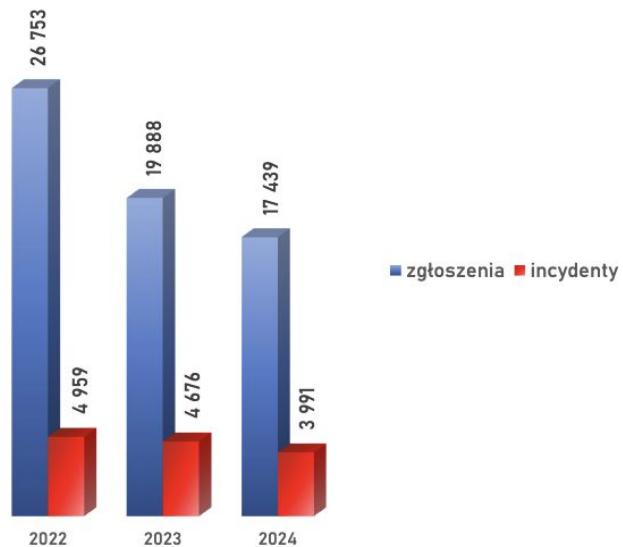


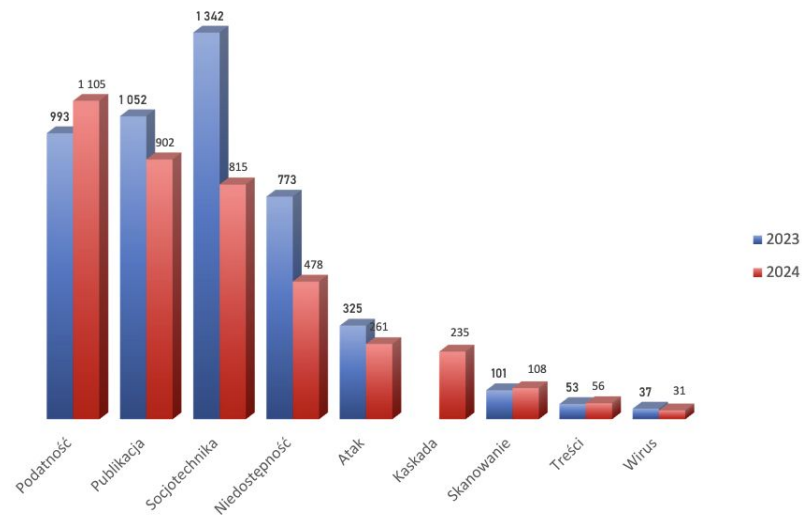
Raport o stanie bezpieczeństwa cyberprzestrzeni RP

2024

STATYSTYKI INCYDENTÓW



Wykres 1. Liczba zarejestrowanych zgłoszeń oraz incydentów w latach 2022-2024



Wykres 3. Liczba incydentów zgłoszonych przez podmioty krajowego systemu cyberbezpieczeństwa w latach 2023 i 2024 z podziałem na kategorie

ZAGROŻENIA IDENTYFIKOWANE W ROKU 2024

Trendy w atakach socjotechnicznych (2024)

Skompromitowane skrzynki gov.pl

Odnutowano przejęcia rządowych kont e-mail oraz skrzynek instytucji międzynarodowych.

Złośliwe kody QR

Stosowano kody QR, aby omijać filtry bezpieczeństwa skanujące zawartość poczty.

Korzystanie z zaufanych serwisów

Wykorzystywano podpisywanie dokumentów DocuSign i usługi jak SharePoint czy Google Drive.

Wizerunek służb mundurowych

Wykorzystywano wizerunek organów ścigania w celu zastraszenia odbiorcy do podjęcia działań.

Kampanie ogólnoeuropejskie

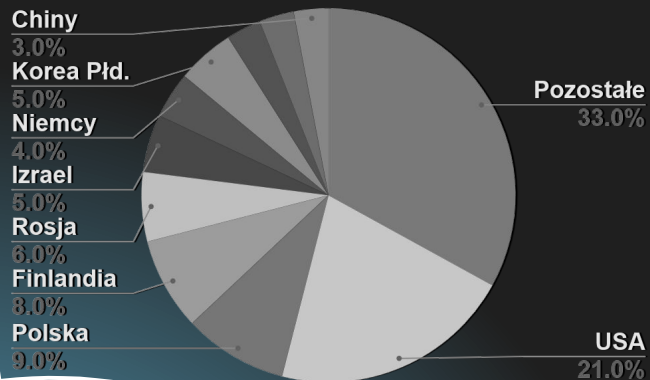
Wiadomości e-mail dystrybuowano do adresatów w wielu państwach członkowskich Unii Europejskiej.

Wizerunek instytucji centralnych

Wykorzystywano wizerunek instytucji szczebla centralnego do legitymizacji prowadzonych działań.

Ataki DDoS

Procentowy rozkład zidentyfikowanych adresów IP biorących udział w atakach DDoS



Dominujące metody ataków:

- TCP SYN/ACK Flood
- UDP Flood
- Przeciążenie serwera zapytaniami HTTP

Wykorzystywano polskie **adresy IP** usług **VPN**.

Średnie czasy ataku wynosiły **od kilkunastu do kilkuset minut**.

Zespół **CSIRT GOV** odnotował w **2024 r.** wysoki poziom zagrożeń w zakresie prób wykorzystania **podatności urządzeń brzegowych, zwłaszcza typu VPN**, jak również **podatności systemów poczty elektronicznej**. Spośród wykorzystywanych podatności identyfikowano również takie, które stanowiły **ataki typu zero-day**.

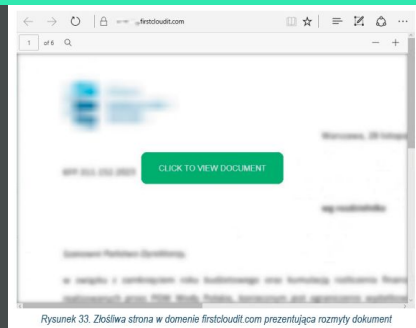
KAMPANIE CYBERSZPIEGOWSKIE

Dominacja i ewolucja technik operacyjnych (2024)

APT28 – Wyrafinowany Phishing

Wykorzystanie „rozmytych dokumentów” w celu wymuszenia na ofierze interakcji i pobrania złośliwego pliku przez protokół WebDAV.

Użycie dedykowanych skryptów w języku Python do kradzieży danych i stabilnej komunikacji z infrastrukturą C2.



Rysunek 33. Złośliwa strona w domenie firstcloudt.com prezentująca rozmyty dokument

UNC1151 – Dezinformacja i Przejęcia Kont

Masowe kampanie phishingowe wymierzone w użytkowników polskich serwisów pocztowych (Interia, WP, Onet) z użyciem sfałszowanych paneli logowania.

Przejmowanie skrzynek e-mail w celu kradzieży wrażliwych informacji oraz późniejszej publikacji treści dezinformacyjnych

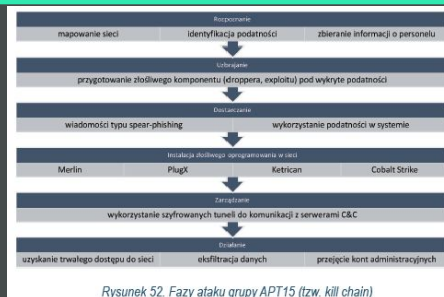


Rysunek 50. Fałszywy panel logowania do poczty Interia

ATP15 – Szpiegostwo w Sektorze Transportu

Wykorzystanie legalnych procesów systemowych lub aplikacji (np. modułów VMware) do ładowania złośliwych bibliotek w celu uniknięcia wykrycia.

Identyfikacja zaawansowanego narzędzia typu RAT (Remote Access Trojan) na skompromitowanych polskich serwerach aplikacyjnych.

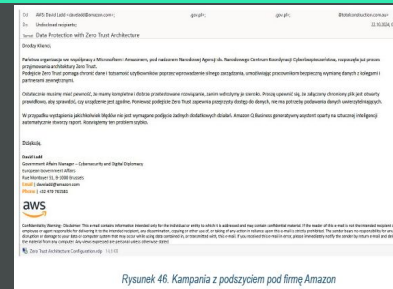


Rysunek 52. Fazy ataku grupy ATP15 (tzw. kill chain)

APT29 – Manipulacja Architekturą Bezpieczeństwa

Podsywanie się pod zaufanych dostawców (np. Amazon) i dystrybucja złośliwych plików konfiguracyjnych RDP (.rdp) podpisanych certyfikatem Let's Encrypt.

Uzyskanie dostępu do zasobów lokalnych ofiary pod pozorem wdrażania nowoczesnych standardów bezpieczeństwa.



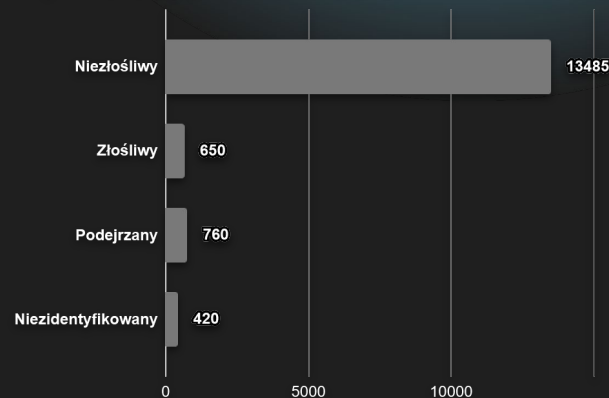
Rysunek 46. Kampania z podszyciem pod firmę Amazon

ZAGROŻENIA – OPROGRAMOWANIE ZŁOŚLIWE

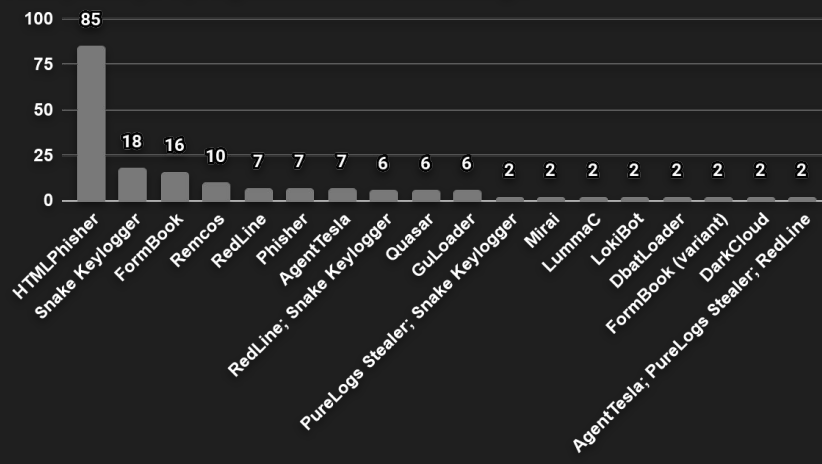
Oprogramowanie złośliwe – statystyka w 2024 roku

Z **15 315** plików **650** uznano za złośliwe.
Dominowało oprogramowanie służące
do **wyłudniania informacji**, zwłaszcza
imitujące strony autentycznych
serwisów (**HTML Phisher**).

Wyniki analizy plików w roku 2024



Klasyfikacja oprogramowania złośliwego



Zachowania analizowanych plików/zasobów internetowych

Dominujące zachowanie to próba omijania zabezpieczeń (**Evader**) przez **złośliwe pliki PDF**.

Wykryte zachowanie	Liczba wystąpień
Evader	528
Phisher	158
Trojan, Spyware, Evader	88
Trojan, Evader	40
Spyware, Evader	26
Trojan	20
Evader, Trojan, Spyware	13
Exploiter, Evader	9
Spyware	8
Exploiter	8

Wykryta reguła	Liczba identyfikacji
Identyfikacja zaszyfrowanego pliku PDF oraz zawierającego formularze	420
Rozpoznanie pliku przez silniki antywirusowe	359
Rozpoznanie domeny, adresu URL przez silniki antywirusowe	229
Modyfikacja kontekstu wątku w innym procesie (thread injection)	175
Próba kradzieży danych wrażliwych z przeglądarki (historia, hasła, ciasteczka)	132
Próba kradzieży danych uwierzytelniających do skrzynki pocztowej (poprzez dostęp do plików/danych w rejestrze)	129
Rozpoznanie oprogramowania złośliwego na podstawie reguł YARA community	127
Identyfikacja zaszyfrowanych danych w dokumencie (ochrona hasłem)	120
Zapis do obcych regionów pamięci przez próbkę	112
Rozpoznanie wypakowanego z próbki pliku przez silniki antywirusowe	86



ARAKIS GOV

Czym jest **ARAKIS GOV?**

Arakis GOV jest to dedykowany, rozproszony system wczesnego ostrzegania o zagrożeniach teleinformatycznych występujących na styku sieci wewnętrznej z siecią Internet.

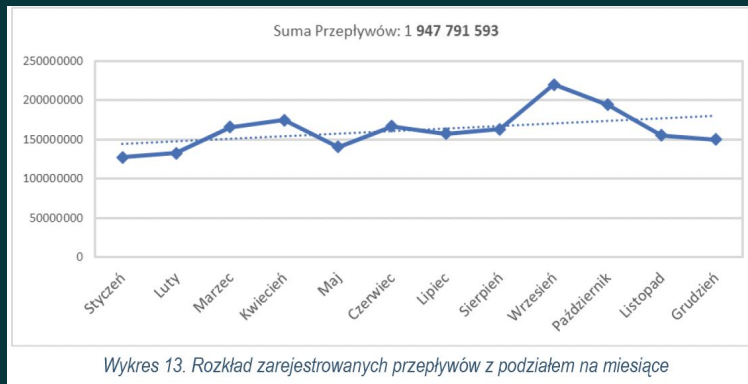
Zadanie 1

Wykrywanie i zautomatyzowane opisywanie zagrożeń sieciowych.

Zadanie 2

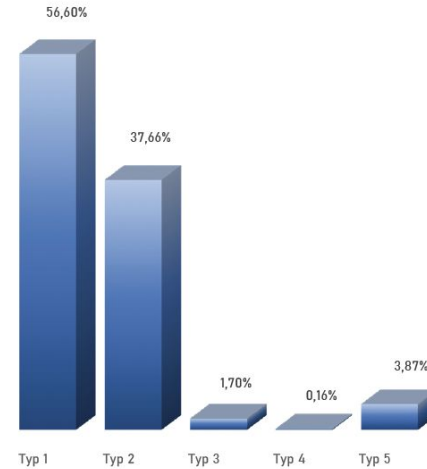
Agregacja, analiza oraz korelacja danych pochodzących z różnych źródeł.

Wykres rozkładu zarejestrowanych przepływów z podziałem na miesiące w projekcie Arakis Gov



Typy alarmów

- Typ 1 – komunikacja do złośliwych adresów
- Typ 2 – skanowania
- Typ 3 – wykryte znane ataki
- Typ 4 – wykryte nieopisane ataki
- Typ 5 – infekcje wewnętrzne



Wykres 15. Procentowy podział alarmów systemu ARAKIS GOV ze względu na typ

Najczęściej atakowane porty i używane loginy i hasła

Najczęściej atakowane porty (**SSH, SMB**) oraz statystyki loginów pokazują, że adwersarze stale liczą na **błędy konfiguracyjne** i **proste hasła użytkowników**

L.p.	DOCELOWY PORT	LICZBA PRZEPŁYWÓW	OPIS
1	22	209 655 929	SSH
2	445	77 442 296	SMB
3	80	40 697 305	HTTP
4	23	40 195 708	Telnet
5	443	21 396 903	HTTPS
6	8728	18 182 036	Mikrotik API
7	2345	10 173 172	DBM
8	3389	9 858 114	RDP
9	8080	9 528 472	HTTP/S
10	25	9 444 386	SMTP

L.p.	TOP 20 LOGINÓW	TOP 20 HASEŁ
1	root	123456
2	admin	123
3	user	password
4	ubuntu	admin
5	sa	12345678
6	test	1234
7	postgres	1
8	oracle	root
9	debian	test
10	ftpuer	12345
11	git	111111
12	deploy	123456789
13	guest	P@ssw0rd
14	steam	123123
15	mysql	abc123
16	es	ubuntu
17	administrator	1234567890
18	dev	admin123
19	hadoop	qwerty
20	user1	1qaz@WSX

OCENA BEZPIECZEŃSTWA SYSTEMÓW TI

Ocena bezpieczeństwa – podsumowanie

W **2024 roku** przeprowadzono ocenę bezpieczeństwa systemów teleinformatycznych w **14 instytucjach administracji rządowej** oraz **infrastruktury krytycznej**.

Łącznie oceniono **64 segmenty sieci/systemów teleinformatycznych** oraz **26 domen/subdomen i stron WWW** w których wykryto **958 podatności**.

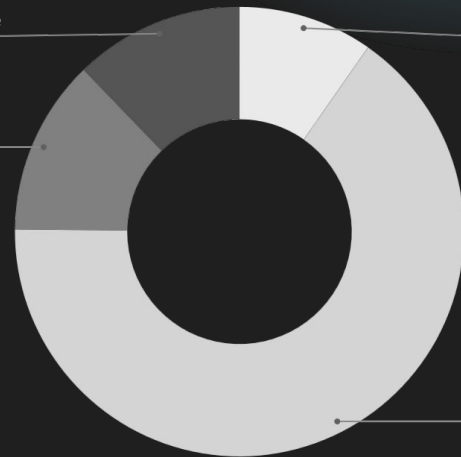
Wykryte podatności w 2024 r.

Krytyczne
12.2%

Wysokie
12.6%

Niskie
9.7%

Średnie
65.4%



Najważniejsze zagrożenia krytyczne oraz wysokie

Niezaktualizowane wersje oprogramowania

- Apache HTTP Server
- OpenSSL
- VMware

Niewspierane wersje oprogramowania

- Microsoft Windows 2008 R2 std.
- Microsoft SQL Server 2008 R2
- FreeBSD 12
- PHP 7.4
- VMware 6.7.x

Usługi/protokoły podatne na ataki

- NTP
- Telnet
- OpenSSH
- JDWP (Java Debug Wire Protocol)
- SSL

Podatności aplikacji webowych

- XSS
- Enumeracja użytkowników
- Ominięcie uwierzytelnienia, w tym ominięcie 2FA
- Blind SQL Injections

Dostęp anonimowy bez uwierzytelniania

- SMTP
- Memcached
- SMB
- phpMyAdmin
- SNMP
- Redis
- Docker API
- NFS
- ElasticSearch
- VMware Aria

POZOSTAŁE DZIAŁANIA ZESPOŁU CSIRT GOV

Sposoby zabezpieczenia wyborów samorządowych

Ochrona infrastruktury wyborczej

CSIRT GOV prowadził bieżącą ocenę bezpieczeństwa systemów i sieci wspierających proces wyborczy

Przeciwdziałanie dezinformacji

Szczególną uwagę poświęcono monitorowaniu wrogich operacji informacyjnych oraz rejestrowaniu domen podszywających się pod oficjalne instytucje.

Szkolenia personelu

Przeprowadzono szereg szkoleń dla administracji wyborczej oraz administratorów IT, mających na celu wzmocnienie odporności na ataki socjotechniczne.

Bieżące monitorowanie

W trakcie trwania wyborów prowadzono wzmożony nadzór nad cyberzagrożeniami w celu zapewnienia ciągłości procesów demokratycznych.

BEZPIECZEŃSTWO ŁAŃCUCHA DOSTAW

Łańcuch dostaw to sieć dostawców i usługodawców uczestniczących w dostarczaniu produktów oraz usług dla danej organizacji.

Cyberprzestępcy obierają na cel dostawców, ponieważ są oni często **słabszymi ogniwami** posiadającymi uprzywilejowany dostęp do **wielu systemów organizacji docelowych**.

Sposoby zabezpieczenia łańcuchów dostaw

Ocena ryzyka

Ocena i zarządzanie ryzykiem w funkcjonującym łańcuchu dostaw, jak i jego nowych/potencjalnych powiązaniach.

Regularne audyty i monitorowanie

Potwierdzenie możliwości bezpiecznej realizacji czynności umownych, jak i ciągłe monitorowanie celem szybkie podejmowania stosownych działań.

Kontrola niezbędnych uprawnień

Regularna weryfikacji przyznawanych uprawnień do zasobów, jedynie na zasadzie tzw. Least Privilege.

Planowanie ciągłości biznesowej

Opracowanie planów ciągłości działania i mitygacji skutków incydentu w przypadku jego wystąpienia.

Szyfrowanie danych

Szyfrowanie danych w transmisji oraz przechowywaniu celem ich właściwego zabezpieczenia.

Wybór dostawców

Wybór dostawców spełniających standardy np. opracowywane przez Międzynarodową Organizację Normalizacyjną (ISO).

Dziękujemy!

Autorzy:

Artur Gęsiarz
Robert Mesek